

Metasploit & Pivoting Concepts

Module 4 — Post-Exploitation · Unit 16

The most famous tool in offensive security — and a warning that comes with it.

Learning objectives

By the end of this unit, you can:

- **Explain** what the **Metasploit Framework** is and why frameworks exist.
- **Navigate** `msfconsole`: `search` → `use` → `show options` → `set` → `exploit`.
- **Tell apart** the four module types: exploit, payload, auxiliary, post.
- **Get** a **Meterpreter** session on an authorized target and run basic post commands.
- **Describe** (awareness only) what **msfvenom** generates.
- **Explain conceptually** pivoting, port forwarding, and SSH tunneling.
- **Describe** (awareness only) what **Active Directory** is.
- **Recommend** defenses: detection/logging, EDR, segmentation, patching.

What is a framework?

- A **framework** is a toolkit that bundles many ready-made tools behind one common way of using them.
- You don't rebuild each tool from scratch — they share settings and a workflow.
- **Upside:** speed, consistency, huge library of exploits.
- **Hidden downside:** it's easy to click the button without understanding what it does.

We learn the framework *and* what's underneath it.

Meet Metasploit

- **Metasploit** is the most popular offensive-security framework.
- It collects thousands of **exploits**, **payloads**, and **post-exploitation tools** under one console.
- You drive it from `msfconsole` — its main command-line interface.
- Preinstalled on **Kali** and the TryHackMe **AttackBox**.

Type a few commands → get a shell. It can feel like magic. That feeling is exactly what we're going to demystify.

The core msfconsole workflow

Step	Command	What it does
1	<code>search</code>	Find a module by service, software, or CVE
2	<code>use</code>	Select that module
3	<code>show options</code>	See its settings (required ones say <code>yes</code>)
4	<code>set</code>	Configure it (e.g. <code>RHOSTS</code> , <code>LHOST</code>)
5	<code>exploit</code> / <code>run</code>	Launch it

RHOSTS = the target. LHOST = you (your listener).

Example: the workflow in action

```
msfconsole           # launch the console
search <keyword>     # find a module
use exploit/<module/path> # select it
show options         # what needs setting?
set RHOSTS <target-ip> # the TARGET
set LHOST <your-ip>   # YOU (shell connects back here)
set PAYLOAD <meterpreter-payload>
exploit              # go
```

Read each option before you run anything. `show options` twice if you have to.

The four module types

Type	What it is	Example
Exploit	Takes advantage of a vulnerability to get in	EternalBlue SMB exploit
Payload	Code that runs <i>after</i> you're in	Meterpreter reverse shell
Auxiliary	Helper — scanners, fuzzers, login checkers	A port scanner
Post	Runs <i>after</i> you have a session	Enumeration / info gathering

Anchor it: exploit = gets you in the door · payload = what runs once you're inside.

Meterpreter & sessions

- A **session** is an active connection to a machine you've compromised.
- **Meterpreter** is a powerful, in-memory payload that gives a rich post-exploitation shell.
- Basic Meterpreter commands:

```
sysinfo      # OS, hostname, architecture
getuid       # which account am I running as?
help         # list available commands
background  # drop back to msf, keep the session
```

`sysinfo` + `getuid` are your proof that the session is real — record them.

Awareness only: msfvenom

- **msfvenom** *generates* standalone payload files — e.g. a malicious `.exe`, `.elf`, or script that connects back to a listener.
- We will **not** build or deploy a payload. Read-only discussion only.
- **Why defenders care:** EDR and antivirus are built to recognize exactly these artifacts and behaviors.

```
# AWARENESS ONLY — do NOT deploy anything outside the lab.  
# msfvenom -p <payload> LHOST=<ip> LPORT=<port> -f <format> -o <file>
```

Don't be "just a tool runner"

A **tool runner** can click the button — but can't explain or adapt when the tool fails.

When does the easy button fail?

- The exploit gets **detected and blocked** by EDR.
- The payload **doesn't match** the target's OS/architecture.
- The target is **patched** — no Metasploit module fits.
- The network won't let the shell **connect back**.

Understanding the manual version is what separates a professional from a tool runner — and makes you a better **defender** too.

Pivoting (concept)

- **Pivoting** = using one compromised machine as a **stepping stone** to reach machines you couldn't reach directly.
- You owned a public web server — but the database is on a **hidden internal network**.

```
[ You ] → [ Foothold box (public) ] → [ Hidden internal box ]
```

- **Port forwarding** = redirecting traffic so you can reach an otherwise-blocked service.
- **SSH tunnel** = using an encrypted SSH connection to carry that traffic.

Pivoting made concrete: SSH local port-forward

```
# Map your local port 8000 to an internal service through the SSH host:
```

```
ssh -L 8000:<internal-host>:80 user@<ssh-server-in-lab>
```

```
# Then, in another terminal/browser:
```

```
curl http://localhost:8000
```

- Visiting `localhost:8000` now reaches the internal service **through** the SSH server.
- That's the essence of pivoting: one machine becomes a stepping stone.
- **Path:** you → SSH server → internal service.

Awareness only: Active Directory

- **Active Directory (AD)** is Microsoft's system for managing many Windows computers, users, and permissions **from one central place**.
- The **Domain Controller** is the central server that runs AD for a network.
- It's how a company manages 5,000 machines without setting up each by hand.

Because AD holds the keys to the whole network, it's a **high-value target**. Deep AD attacks are **beyond this course** — we just want you to know it exists.

The defense (always close the loop)

Defense	What it stops
Detection / logging	Exploits and sessions leave log entries and network signatures
EDR	Flags Meterpreter-style in-memory behavior on the host
Network segmentation	Limits how far an attacker can pivot
Patching	Removes the vulnerability the exploit module relies on

Every capability we showed — exploit, Meterpreter, pivot — has a defense that detects or stops it.

Ethics & Authorization

The easier the tool, the MORE the authorization rule matters.

Metasploit doesn't ask if you have permission — **you** are responsible for that. The same `msfconsole` on an authorized TryHackMe box would be a **felony** pointed at a stranger's server.

Key vocabulary

Term	Meaning
Framework	Toolkit bundling many tools behind one workflow
Module	A single tool inside Metasploit
Exploit / Payload	Gets you in / what runs once you're in
Auxiliary / Post	Helper tool / runs after you have a session
Meterpreter	Powerful in-memory post-exploitation shell
Session	Active connection to a compromised machine
RHOSTS / LHOST	The target / you (your listener)
Pivoting	Using one box as a stepping stone to others
SSH tunnel	Encrypted connection carrying other traffic



Lab launch

- **Platform:** TryHackMe — a beginner **Metasploit** room, on the AttackBox or Kali.
- **Read the Safety & authorization reminder aloud** with a partner first.
- **Goal:** open a **Meterpreter session** on the authorized target, run `sysinfo` + `getuid`, run one post module.
- **Document** everything in your lab journal: workflow, RHOSTS/LHOST, session proof, one defense.
- **Optional:** the instructor's simple `ssh -L` port-forward demo.

Aim Metasploit at the authorized target IP **only**. If unsure a target is in scope — stop and ask.

Recap

- **Metasploit** is a framework: `search → use → show options → set → exploit`.
- Four module types: **exploit, payload, auxiliary, post**. Meterpreter is a payload.
- **Session** = connection to a compromised box; `sysinfo` + `getuid` prove it.
- **msfvenom** generates payloads (awareness only); **EDR** is built to catch them.
- **Pivoting** = one box as a stepping stone; SSH `-L` makes it concrete.
- **AD** = central Windows management (awareness only).
- Defenses: **detection, EDR, segmentation, patching**.

Exit ticket / discussion

1. Put the msfconsole workflow in order, and say what **RHOSTS** and **LHOST** mean.
2. Name the four module types with one example each.
3. Explain **pivoting** to a friend in two sentences.
4. Finish: *"The most important reason not to be 'just a tool runner' is ____."*

Next unit: Reporting & Professional Communication + Capstone Kickoff